

One Step Ahead

Security Architecture & Smart Split White Paper

Version: 1.0

Status: Public Technical Disclosure

Product: One Step Ahead (macOS & iOS)

Author: Solid Software Lab

Abstract

One Step Ahead (OSA) is an offline-first security application for macOS and iOS designed to protect confidential material such as digital currency wallets (BIP-39 seed phrases), login credentials, sensitive text, and classified documents in the form of images and PDF files.

OSA combines strong cryptographic encryption with a deterministic threshold-based distribution method (Smart Split) that eliminates single points of failure. Sensitive data is transformed into a fully encoded representation and divided into three fragments, of which any two are sufficient for deterministic reconstruction.

OSA operates entirely offline and does not require or establish any internet connection. No sensitive data is transmitted, cached, or stored outside of explicit user action. The application uses no third-party frameworks or dependencies, performs no tracking, and retains no information about protected content. The system is designed to be auditable, reconstructable without vendor lock-in, and resilient against device loss or partial compromise.

1. Problem Statement

Managing sensitive information presents fundamental challenges:

Single point of failure

Loss or compromise of a single device, cloud account, or backup often results in irreversible data loss.

Opaque security tooling

Many consumer and professional security tools present themselves as “secure” without clearly exposing their operational assumptions, trust, or failure. This includes:

- **Undisclosed cloud dependencies** - recovery, or key management may silently depend on remote services, even when the product appears to operate locally.
- **Centralized recovery mechanisms** - users are often required to trust a single recovery factor (passwords, accounts, vendors, or custodial services), creating implicit single points of failure.
- **Unverifiable key handling** - encryption keys may be derived from user credentials, reused across sessions, cached, or transmitted in ways that are not observable or independently verifiable.
- **Closed recovery paths** - data recovery may require the original application, vendor infrastructure, or proprietary backend services, preventing independent reconstruction.

Usability vs. security trade-offs

Highly secure systems often exclude non-technical users, while usable systems frequently weaken security guarantees.

In cryptocurrency and OPSEC contexts, these issues are escalated: mnemonic phrases and credentials cannot be rotated easily, and compromise or loss is often permanent.

One Step Ahead application addresses these challenges by prioritizing resilience, transparency, and offline control, while remaining usable across technical skill levels.

2. Design Goals

One Step Ahead is designed to:

- Eliminate single points of failure with a 2 out of 3 fragment reconstruction
- Protect high-value confidential information using encryption by default
- Ensure integrity with hash-based verification
- Provide human-readable recovery in text form for non-technical users
- Operate entirely offline on user-controlled devices
- Avoid third-party dependencies and cloud services
- Enable deterministic recovery with explicit thresholds
- Allow independent reconstruction without vendor lock-in
- Make security properties explicit and auditable
- Enable independent reconstruction using open-source tooling, ensuring OSA itself is never a single point of failure for data recovery.

3. Threat Model

One Step Ahead is designed to mitigate:

- loss or destruction of a single device or fragment
- accidental deletion of one fragment
- unauthorized access to a single fragment
- data corruption (detected via integrity with hash-based verification)

One Step Ahead is not designed to protect against:

- malware present at the moment of encryption in the device (advanced adversary)
- coercion or forced disclosure of two or more fragments
- loss of all fragments

4. Privacy & Data Handling

One Step Ahead operates entirely offline and does not require or establish any internet connection at any point during operation. No data is transmitted to external servers, and no third-party frameworks, SDKs, or analytics tools are used within the application.

Sensitive data entered by the user is retained in memory only for the duration of the active session to preserve usability. It is never written to disk, cached, logged, or persisted beyond the application session. All data is cleared when the application is closed or when the user explicitly clears entries. Fragments and reconstructed content are only written to storage when explicitly initiated by the user.

The only data retained by the application is non-sensitive user preferences, such as selected output type, Smart Split method, and terms of use acceptance. This data contains no information about the protected content.

5. Smart Split v2: Cryptographic Architecture

One Step Ahead is built on three conceptual layers: Cryptographic Protection, Deterministic Distribution (Smart Split), and Representation (Readable, QR, Binary). Each layer has clearly defined responsibilities and security properties.

Seed Generation

For each encryption operation, a cryptographically random 66-character seed is generated using a alphanumeric character set (a–z, A–Z, 0–9). This produces approximately 392 bits of entropy, which substantially exceeds the 256-bit security level of AES-256-GCM. The seed is ephemeral — it is never stored in full in any single output and exists in memory only for the duration of the operation.

Key Derivation

The AES encryption key is derived by applying SHA-256 to the full 66-character seed. This produces a fixed-size 256-bit key suitable for AES-256-GCM. SHA-256 is appropriate here because the seed is a high-entropy randomly generated value — not a user-supplied password. Password-based key derivation functions such as PBKDF2 or Argon2 are designed to compensate for low-entropy inputs and are unnecessary in this context. All 66 seed characters influence the derived key — any single character change produces a completely different key with no truncation or entropy loss.

Encryption

Data is encrypted using AES-256-GCM. A unique random nonce is generated for every encryption operation. The resulting output is a combined blob containing the nonce, ciphertext, and GCM authentication tag. AES-256-GCM provides both confidentiality and authenticated integrity — any tampering with the ciphertext will cause decryption to fail explicitly.

Input Normalisation

Before encryption, input data is normalised to a canonical form to ensure deterministic behaviour across platforms and sessions. For digital wallets, BIP-39 validation is performed prior to encryption — each word is validated against the BIP-39 word list and stored as its corresponding index number rather than the word itself. This ensures the canonical input is language-agnostic and unambiguous. If any word fails BIP-39 validation, the operation is rejected before encryption is attempted.

Seed Splitting

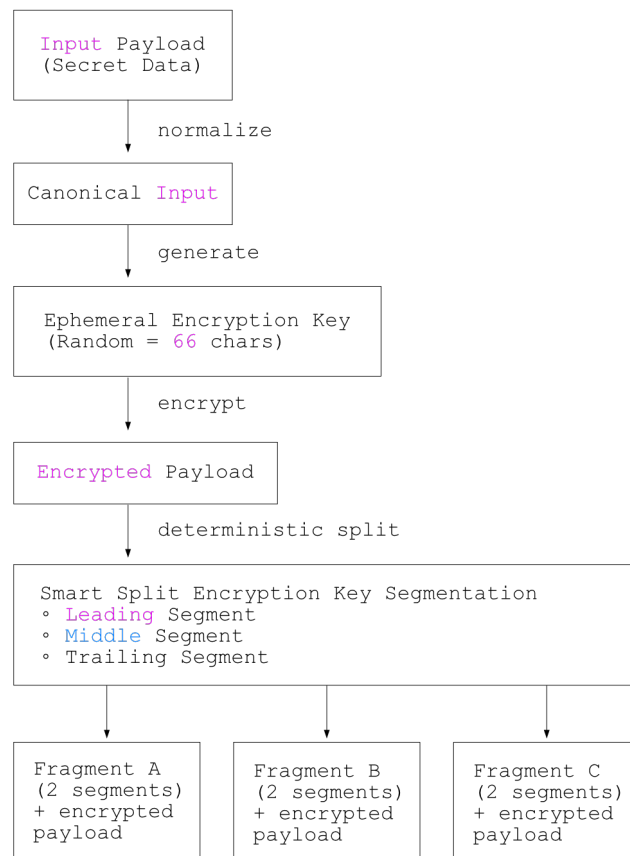
The 66-character seed is divided into three equal non-overlapping portions of 22 characters each: leading (characters 1–22), middle (characters 23–44), and trailing (characters 45–66). Each fragment receives exactly two of the three portions, identified by label. Any two fragments are sufficient to reconstruct the full seed, from which the AES key can be re-derived and the ciphertext decrypted. The splitting process is fully deterministic and introduces no additional randomness beyond the initial seed generation.

Smart Split does not provide secrecy on its own — its purpose is resilience, preventing data loss and eliminating single points of failure. When combined with encryption, Smart Split protects the encryption seed itself, ensuring both confidentiality and recoverability.

What Smart Split Is Not

Smart Split is not a cryptographic secret-sharing scheme such as Shamir Secret Sharing. The encrypted payload is replicated in full across all fragments — only the encryption seed is segmented. Confidentiality is enforced entirely through encryption, while Smart Split provides availability and fault tolerance.

Unlike Shamir Secret Sharing, which provides information-theoretic security where individual shares reveal nothing about the secret, Smart Split segments the seed into contiguous portions. Confidentiality against a single fragment is enforced computationally through AES-256-GCM encryption and the infeasibility of brute-forcing the missing seed portion.



6. Data Representation

OSA supports three representation modes depending on data type, use case and Smart Split version.

Smart Split versions:

Mode	Version	Data Types	Encryption	Storage Format
Readable	v1 (legacy)	Digital wallets, logins, plain text	No	Human-readable fragments
QR	v1 (legacy)	Digital wallets, logins, plain text	No	QR-encoded fragments
QR	v2 (default)	Digital wallets, logins, plain text	Yes	QR-encoded fragments
Binary	v2	Images, PDFs	Yes	.s32 files

Notes: QR is a transport/representation layer; it does not alter security properties.

Smart Split Version 2

This method introduces a fully encoded model for all supported data types such as digital wallets (with BIP-39 validation), login credentials, plain text, images and PDF files.

No meaningful information about the protected content is exposed in filenames, links, or metadata. Encoded payloads may be represented as text, QR codes, or binary files.

Every fragment contains full encrypted data and portion of encryption seed. Any two fragments reconstruct the encryption seed. Reconstruction is deterministic and order-independent.

Smart Split Version 1 (Legacy)

Smart Split Version 1 operates on plaintext data directly, without encryption. The input is divided into three human-readable fragments, where each fragment contains two thirds of the original data with one third omitted. Any two fragments are sufficient to reconstruct the original input. While this approach prioritizes readability and simplicity — making it accessible without any software for reconstruction — it carries a significant security trade-off: any single fragment exposes two thirds of the protected content without encryption. For this reason, Smart Split Version 1 is considered a legacy mode and is recommended only for use cases where readability and simplicity are explicitly preferred over confidentiality.

Binary Fragment Format (.s32)

Binary data types such as images and PDFs are stored as .s32 files. This is a proprietary binary container format used by One Step Ahead to store encrypted, split binary fragments. Each .s32 file contains the full encrypted payload and two of three seed portions required for reconstruction. The file structure and internal content are intentionally opaque — no information about the protected data is exposed within the file itself.

Filenames follow a human-readable convention that includes a short random identifier and a creation timestamp, designed to help users manage multiple fragments across devices and locations. This is a deliberate usability compromise — the filename exposes non-sensitive operational metadata only, and reveals nothing about the protected content. However, users operating under stricter OPSEC requirements should be aware that a shared timestamp across fragments could assist an attacker in physically correlating fragments across locations. In such cases, renaming the files is fully supported — there is no filename-based correlation between fragments. Fragment matching relies exclusively on the identifier embedded within the encoded payload.

Note: Only the filename may be changed — the .s32 extension must be preserved for the application to correctly identify and process the file.

Integrity Verification

Each encoded payload includes integrity metadata serving two purposes: fragment correlation and reconstruction validation.

For digital wallets, login credentials, and plain text, integrity metadata allows the user to identify matching fragments. Reconstruction will fail if mismatched fragments are combined, however no explicit checksum verification is performed — failure manifests as invalid output.

For binary data types such as images and PDFs, integrity verification is performed explicitly during reconstruction. The mechanism detects partial corruption, accidental modification, and fragment mismatches. Reconstruction fails immediately and explicitly when verification does not pass.

7. Reconstruction

Reconstruction requires any two matching fragments and is performed entirely offline within the application. The process is order-independent — the application determines which fragments are present from the embedded seed portion labels and derives the missing portion automatically.

macOS

On macOS, QR-based fragments are reconstructed by scanning any two matching QR codes using the device camera. Binary .s32 fragments are reconstructed by dragging and dropping or manually selecting any two matching files. Upon successful reconstruction, the original file is restored in its original format — supported file types are PDF, JPG, and PNG. The user is presented with an option to download the reconstructed file to the machine.

If two fragments from different splits are provided, the application will detect the identifier mismatch and fail explicitly. For binary .s32 files, the application additionally detects and reports file corruption.

iOS

On iOS, reconstruction is supported for QR-based fragments only. The user scans any two matching QR codes using the device camera to reconstruct the original content. Binary file reconstruction is not currently supported on iOS due to file system limitations.

8. Version History

Version	Date	Status	Notes
1.0	2026-03-30	Public Technical Disclosure	Initial release